

Phase C — Full WordPress User Management

Connector version: 1.2.12 **Status:** Implemented and unit/feature tested. Behaviours that require a live WordPress install or the full Laravel + Postgres + Redis stack are listed explicitly under *Live-site verification* — they cannot be exercised on the build VM and must be confirmed on staging.

This document also recaps two smaller fixes shipped alongside Phase C:

- **Fix 1 — Instant update-count refresh** after “Update Plugins”.
 - **Fix 2 — Explicit online/offline lifecycle signals** on connector activation/deactivation.
-

1. What was built

A complete **Users** management system that lets a MarQira customer manage the WordPress users of every managed website **without ever logging into the individual wp-admin dashboards**. It spans all three layers of the product:

Layer	Responsibility
Connector (marqira-connector)	New signed REST endpoints that wrap WordPress core user APIs (WP_User_Query, wp_insert_user, wp_update_user, wp_delete_user, get_editable_roles, ...).
API (apps/api, Laravel)	Dashboard-facing endpoints that authorize the MarQira user, relay to the correct site over HMAC, enforce privilege rules, and provide the multi-site bulk workflow.
Dashboard (apps/dashboard, React/TS)	A polished Users tab per site, create/edit/delete modals with content-reassignment, and a global “Add User to Websites” bulk flow with per-site results and retry.

This maps to spec sections §3–§13.

2. Connector endpoints

New file: wordpress/marqira-connector/includes/class-marqira-users.php (class Marqira_Users, wired in marqira-connector.php).

All routes are POST under `marqira/v1/users/...` and are protected by the same HMAC signature scheme as every other connector endpoint (`Marqira_Hmac_Server::verify`). The permission callback signs against `$request->get_route()`, so there are no dynamic path segments to canonicalise.

Route	Purpose
<code>users/list</code>	Paginated list with role filter + search (<code>WP_User_Query</code>).
<code>users/get</code>	Single user detail. Never returns <code>user_pass</code> .
<code>users/create</code>	<code>wp_insert_user</code> with full field + meta support, validation, role guard.
<code>users/update</code>	<code>wp_update_user</code> ; password is set only when a new one is supplied.
<code>users/delete</code>	<code>wp_delete_user</code> with optional content reassignment; last-admin protection.
<code>users/roles</code>	Live role list from <code>get_editable_roles()</code> — default AND custom roles .
<code>users/reassign-candidates</code>	Eligible users to receive content on delete (excludes the target).

Key guarantees:

- **No secrets ever leave the site.** Password hashes, salts, auth cookies and API secrets are never included in any response payload.
- **Last-administrator protection.** Deleting or demoting the final administrator is rejected before any change is made.
- **Idempotency.** `create` honours an `idempotency_key`; a repeated key within 24h returns the original result instead of creating a duplicate account (stored via a WP transient, prefix `marqira_user_idem_`).
- **Native WordPress APIs only.** Deletion and reassignment use `wp_delete_user($id, $reassign_to)` so ownership is transferred by WordPress itself, not by rewriting DB rows.
- **Audit.** Every mutating action is written through `Marqira_Logger`.

3. API endpoints (dashboard-facing)

New controller:

`apps/api/app/Http/Controllers/Api/Dashboard/SiteUserController.php`. Routes registered in `apps/api/routes/api.php` inside the authenticated dashboard group.

Method & path	Action
GET /api/dashboard/sites/{uuid}/wp-users	List (role filter, search, pagination).
GET /api/dashboard/sites/{uuid}/wp-users/{id}	Show one user.
POST /api/dashboard/sites/{uuid}/wp-users	Create.
PUT/PATCH /api/dashboard/sites/{uuid}/wp-users/{id}	Update.
DELETE /api/dashboard/sites/{uuid}/wp-users/{id}	Delete (reassign_to or force_delete).
GET /api/dashboard/sites/{uuid}/wp-roles	Available roles for the site.
GET /api/dashboard/sites/{uuid}/wp-users/reassign-candidates	Eligible reassignment targets.
POST /api/dashboard/wp-users/bulk-create	Create one user across many sites (§8).

Behaviours:

- **Authorization / IDOR.** Every request resolves the site through `findSiteOrFail`, which scopes by organization **and** `visibleTo($user)`. A user who cannot see a site gets 404 — they cannot enumerate or act on it.
- **Privilege escalation block.** `guardRole` refuses to create or promote a user to administrator unless the MarQira actor is authorized (platform owner or organization owner). A subscriber-level MarQira user receives 403.
- **Connector capability gate.** `assertManageable` returns:
 - 409 `site_revoked` if the site's pairing is revoked.
 - 422 `connector_unsupported` if the connector is older than 1.2.12 (`Site::USER_MGMT_MIN_VERSION`).
- **Predictable errors.** Connector failures are relayed with meaningful status codes and a structured body.

Bulk create (§8/§9)

POST /api/dashboard/wp-users/bulk-create accepts the user detail once, a default role, and a list of { uuid, role? } targets. For each site it returns an individual row with status created / failed / skipped and a message. A deterministic `idempotency_key = sha256(operationId | uuid | username)` is sent to each connector, so **retrying only the failed sites re-uses the same operation id and never duplicates the accounts that already succeeded** (§9).

4. Dashboard UI

- **apps/dashboard/src/components/WpUsers.tsx** — the per-site **Users** tab: search box, role filter (populated live from the site), Add-User button, sortable table with pagination, and success flash. Includes CreateUserModal, EditUserModal (new-password-only, never shows a stored password), and DeleteUserModal with a reassign-vs-force radio and a searchable candidate picker (reassign is the safe default).
- **apps/dashboard/src/pages/AddUserToWebsites.tsx** — the global **Add User to Websites** flow (§8): enter details once, pick a default role, multi-select sites (checkboxes, select-all, search), override the role per site, then create. A results panel shows a per-site outcome and offers **Retry failed only**.
- Wired into navigation (Layout.tsx → “Add User to Sites”) and routing (App.tsx → /wp-users/add-to-websites). The old telemetry-only Users tab in WebsiteDetail.tsx was replaced by the new WpUsersTab.

The dashboard builds cleanly (np^x tsc --noEmit and npm run build both succeed).

5. Security (§11)

Concern	Mitigation
Authentication	Dashboard endpoints require an authenticated MarQira session; connector endpoints require a valid HMAC signature.
Authorization / privilege escalation	guardRole — administrator creation/promotion only for authorized actors.
IDOR	findSiteOrFail scopes every lookup by org + visibleTo; unknown sites return 404.
Replay / tampering	HMAC canonical string binds method, path, timestamp, nonce and body hash; connector rejects stale/replayed requests.
Password handling	Only <i>new</i> passwords are ever sent; hashes/salts are never returned or logged.
User enumeration	Cross-tenant lookups return 404, not 403.
Sensitive logging	Audit entries record actor, target, action and result — never plaintext passwords.
Last-admin lockout	Delete/demote of the final administrator is blocked at the connector.
Idempotency	Deterministic keys prevent duplicate

Concern	Mitigation
	accounts on ret/replay of bulk operations.

6. Fix 1 — Instant update-count refresh

Problem: after clicking “Update Plugins” the dashboard still showed the old pending count until the next heartbeat.

Fix: - API (UpdateCommandController::ack) — when a command completes, it immediately adjusts the stored counters by command type: all-plugins → plugin_updates_count = 0; all-themes → theme_updates_count = 0; core → core_update_available = false; connector self-update → decrement the plugin count. - Connector (class-marqira-remote-update.php) — send_ack() now triggers refresh_updates_and_beat() on completion so the freshest state is pushed right away.

Tested by 5 new assertions in RemoteUpdateCommandTest.php (counts reset per type; a failed update leaves counts untouched).

7. Fix 2 — Explicit online/offline signals

Problem: deactivating the connector left the site looking “online” until it timed out.

Fix: - Connector — new Marqira_Heartbeat::send_status_signal(\$state, \$reason); the plugin sends offline on deactivate and online on activate. - API — new SiteStatusController + POST /site-status (HMAC-authenticated). It sets the site online/offline with a reason and records an site.connector_{state} audit entry. Revoked sites are rejected at auth.

Tested by 4 new assertions in SiteStatusSignalTest.php.

8. Testing

All automated checks were run on the build VM.

- **Connector harness** (php tests/run.php): **200 passed**, 4 pre-existing failures unrelated to this work (they fatally require wp-admin/includes/plugin.php, which is not present in the harness). New file tests/test-users.php contributes 30 passing assertions covering list/filter/search, get, create, update (password never echoed), role change, last-admin protection on delete + demote, custom-role handling, content reassignment, and reassign-candidate exclusion.

- **API suite** (php artisan test): **298 passed** (996 assertions), including the new SiteUserManagementTest.php (21 tests) and the Fix 1 / Fix 2 tests.

Spec §14 coverage

Requirement	Where verified
List users / role filter / search	connector test-users.php, API SiteUserManagementTest
Create subscriber	both suites
Create administrator where authorized	API test
Reject administrator where unauthorized	API test (subscriber → 403)
Edit name / email / password / role	both suites
Custom role handling	connector test (custom shop_manager)
Delete user / with content / reassignment	connector + API tests
Protected (last) administrator	connector test (delete + demote blocked)
Same account on multiple websites	API bulk test
Partial failure + retry failed only	API bulk test (created/failed/skipped rows; idempotency key)
Website offline / revoked during operation	API test (409 / 422)
Existing username / email / invalid email / invalid role	validation tests
Malformed / unauthorized API request	API tests (422 / 401 / 404)

Live-site verification (cannot run on the build VM)

The VM has no running WordPress or full Laravel+Postgres+Redis stack, so the following must be confirmed on staging:

- End-to-end create/edit/delete against a real wp-admin and confirming the change in WordPress.
- Content reassignment leaving posts owned by the replacement user after a real delete.
- Behaviour on **WordPress 7.1** and the supported previous versions (§14). The connector uses only core user APIs that are stable across these versions.

- A genuinely unreachable / slow site during a bulk operation surfacing as a per-site failure.
-

9. Deployment (Coolify)

No database migration is required for Phase C. The new functionality adds no columns or tables:

- SiteUserController and the connector routes are stateless relays.
- Site::USER_MGMT_MIN_VERSION is a PHP constant, not a schema change.
- Fix 1 reuses existing counter columns; Fix 2 reuses existing status columns.

Deployment steps:

1. **Ship the connector.** Distribute releases/marqira-connector-1.2.12.zip and update managed sites. User management is gated on connector $\geq 1.2.12$; older sites return 422 connector_unsupported (handled gracefully in the UI).
2. **Deploy the API** (apps/api) via the usual Coolify pipeline. No php artisan migrate needed for this phase.
3. **Deploy the dashboard** (apps/dashboard) — standard build/deploy; no env changes.

No new environment variables, queues, or cron entries are introduced by Phase C.